Lab 5: Static Code Analysis

SRN: PES1UG24AM321
Program: Supplier Purchase Order Tracker (L5_18_supplier_orders)
Repository: https://github.com/Vocod3r/L5_18_supplier_orders
Tools: Pylint, Bandit, Flake8

Results

Pylint: 2.41/10 before, 10.00/10 after
Bandit: 3 issues before (1 High, 1 Medium, 1 Low), 0 after
Flake8: 4 issues before, 0 after
The program output (1 540) is the same before and after.

1. Running the original program

```
Downloading platformdirs-4.13.0-py3-none-any.whl (32 kB)
Using cached pyyaml-6.0.3-cp311-cp311-win_amd64.whl (158 kB)
Downloading stevedore-5.9.1-py3-none-any.whl (54 kB)
Downloading tomlkit-0.15.1-py3-none-any.whl (49 kB)
Installing collected packages: tomlkit, stevedore, PyYAML, pyflakes, pycodes
tyle, platformdirs, mypy-extensions, mccabe, dill, astroid, isort, flake8, p
ylint, bandit
Successfully installed PyYAML-6.0.3 astroid-4.3.4 bandit-1.9.4 dill-0.4.1 fl
ake8-7.4.1 isort-9.0.2 mccabe-0.7.0 mypy-extensions-1.1.0 platformdirs-4.13.
0 pycodestyle-2.15.0 pyflakes-4.0.3 pylint-4.1.3 stevedore-5.9.1 tomlkit-0.1
5.1

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>python supplier_orders.py

notifying warehouse about Acme
1 540
```

Figure 1: Installing the tools and running the original program.

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>mkdir reports\before

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>pylint supplier_orders.py
 > reports\before\pylint_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>bandit -r supplier_orders
.py > reports\before\bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>flake8 supplier_orders.py
 > reports\before\flake8_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 2: Saving the baseline reports to reports\before.

2. Baseline reports

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>mkdir reports\before

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>pylint supplier_orders.py > r
eports\before\pylint_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>bandit -r supplier_orders.py
> reports\before\bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>flake8 supplier_orders.py > r
eports\before\flake8_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>type reports\before\bandit_re
port.txt
Run started:2026-10-15 05:52:38.122243+00:00

Test results:
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\supplier_orders.py:11:17
10          global order_total
11          conn.execute("INSERT INTO orders (supplier, item, quantity, received) VALUES ('%s', '%s', %d, 0)" % (supplier, item, quantity))
12          order_total+=quantity

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\supplier_orders.py:21:4
20      def notifyWarehouse(supplier):
21          os.system("echo notifying warehouse about " + supplier)
22

--------------------------------------------------
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
```

Figure 3: Bandit baseline: SQL injection (B608) on line 11 and shell injection (B605) on line 21.

```
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\supplier_orders.py:27:4
26              conn.execute("DELETE FROM orders WHERE received = 1")
27          except Exception:
28              pass
29

--------------------------------------------------

Code scanned:
        Total lines of code: 29
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 1
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 2
Files skipped (0):
```

Figure 4: Bandit baseline: try/except/pass (B110) on lines 27-28; 3 issues in total.

Pylint and Flake8 baseline (from reports/before):

```
************* Module supplier_orders
supplier_orders.py:5:0: C0301: Line too long (122/100) (line-too-long)
supplier_orders.py:11:0: C0301: Line too long (131/100) (line-too-long)
supplier_orders.py:1:0: C0114: Missing module docstring (missing-module-docstring)
supplier_orders.py:6:0: C0103: Constant name "order_total" doesn't conform to UPPER_CASE naming style (invalid-name)
supplier_orders.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:9:0: C0103: Function name "placeOrder" doesn't conform to snake_case naming style (invalid-name)
supplier_orders.py:9:15: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:10:4: W0603: Using the global statement (global-statement)
supplier_orders.py:11:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
supplier_orders.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:16:0: C0103: Function name "markReceived" doesn't conform to snake_case naming style (invalid-name)
supplier_orders.py:16:17: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:16:33: W0613: Unused argument 'remarks' (unused-argument)
supplier_orders.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:20:0: C0103: Function name "notifyWarehouse" doesn't conform to snake_case naming style (invalid-nam
supplier_orders.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:24:12: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:27:11: W0718: Catching too general exception Exception (broad-exception-caught)
supplier_orders.py:31:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:31:0: C0103: Function name "pendingCount" doesn't conform to snake_case naming style (invalid-name)
supplier_orders.py:31:17: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:35:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 2.41/10
```

```
supplier_orders.py:5:80: E501 line too long (122 > 79 characters)
supplier_orders.py:11:80: E501 line too long (131 > 79 characters)
supplier_orders.py:12:16: E225 missing whitespace around operator
supplier_orders.py:32:80: E501 line too long (87 > 79 characters)
```

3. Fixing Bandit issues

- Replaced os.system() with print() and removed import os (shell injection).
- Used ? placeholders instead of % formatting in the INSERT query (SQL injection).
- Caught sqlite3.Error and printed it instead of except Exception: pass.

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>python supplier_orders.py
notifying warehouse about Acme
1 540

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>bandit -r supplier_orders.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-15 13:27:12.096659+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 29
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assignments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 5: Program still prints 1 540; Bandit reports no issues.

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git add supplier_orders.p
y reports
warning: in the working copy of 'reports/before/flake8_report.txt', LF will
be replaced by CRLF the next time Git touches it

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git commit -m "Fix Bandit
 security issues: SQL injection, shell injection, try-except-pass"
[main a9a04c7] Fix Bandit security issues: SQL injection, shell injection, t
ry-except-pass
 4 files changed, 87 insertions(+), 4 deletions(-)
 create mode 100644 reports/before/bandit_report.txt
 create mode 100644 reports/before/flake8_report.txt
 create mode 100644 reports/before/pylint_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git log --oneline
a9a04c7 (HEAD -> main) Fix Bandit security issues: SQL injection, shell inje
ction, try-except-pass
9b72a43 (origin/main, origin/HEAD) Add Lab 5 static analyis scenario

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>flake8 supplier_orders.py
supplier_orders.py:1:1: F401 'os' imported but unused
supplier_orders.py:5:80: E501 line too long (122 > 79 characters)
supplier_orders.py:11:80: E501 line too long (123 > 79 characters)
supplier_orders.py:12:16: E225 missing whitespace around operator
supplier_orders.py:32:80: E501 line too long (87 > 79 characters)

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 6: Bandit fixes committed; Flake8 issues remaining.

4. Fixing Flake8 issues

- Removed the unused import os (F401).
- Split long SQL lines to under 79 characters (E501).
- Added spaces around += (E225).

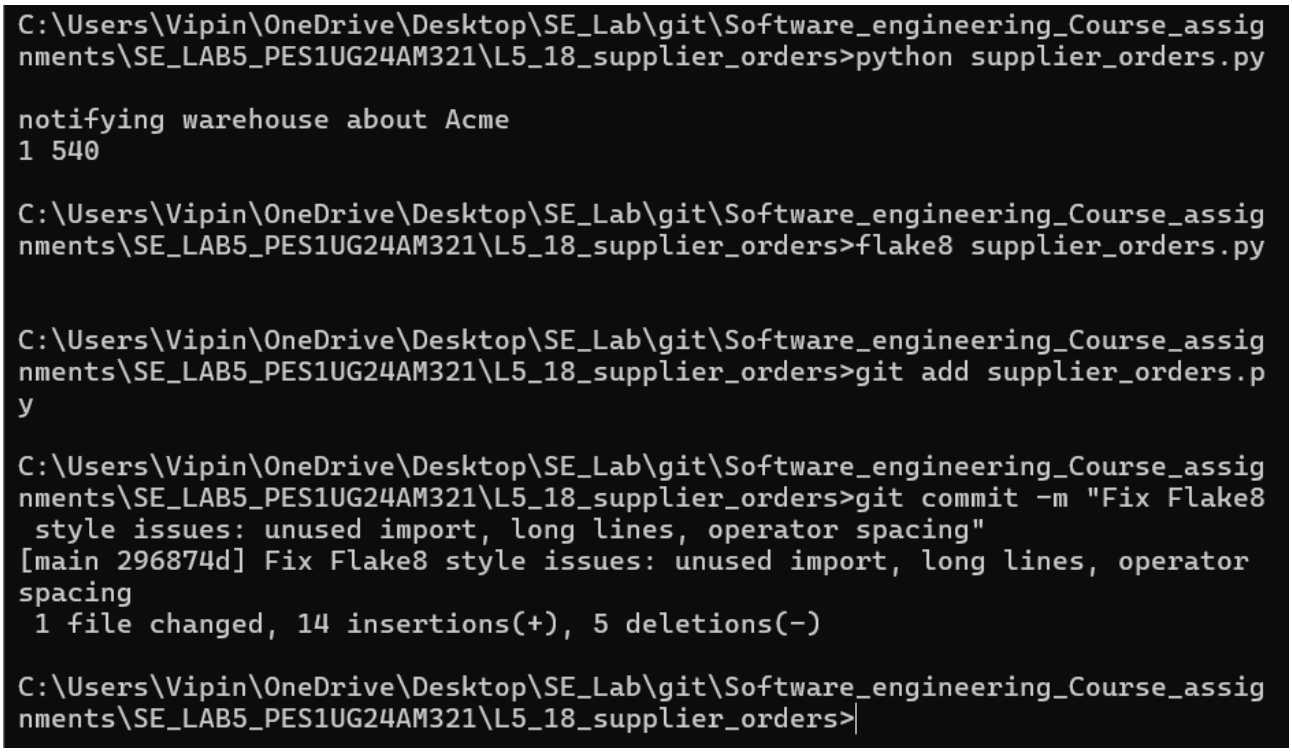


Figure 7: Flake8 clean and Flake8 fixes committed.

5. Fixing Pylint issues

- Renamed functions to snake_case (C0103).
- Added module and function docstrings (C0114, C0116).
- Moved the database connection into create_store() (W0621).
- Replaced the global order_total with a SUM(quantity) query (W0603).
- Stored the remarks argument in a new column (W0613).

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>pylint supplier_orders.py

************* Module supplier_orders
supplier_orders.py:1:0: C0114: Missing module docstring (missing-module-docs
tring)
supplier_orders.py:8:0: C0103: Constant name "order_total" doesn't conform t
o UPPER_CASE naming style (invalid-name)
supplier_orders.py:11:0: C0116: Missing function or method docstring (missin
g-function-docstring)
supplier_orders.py:11:0: C0103: Function name "placeOrder" doesn't conform t
o snake_case naming style (invalid-name)
supplier_orders.py:11:15: W0621: Redefining name 'conn' from outer scope (li
ne 3) (redefined-outer-name)
supplier_orders.py:12:4: W0603: Using the global statement (global-statement
)
supplier_orders.py:22:0: C0116: Missing function or method docstring (missin
g-function-docstring)
supplier_orders.py:22:0: C0103: Function name "markReceived" doesn't conform
 to snake_case naming style (invalid-name)
supplier_orders.py:22:17: W0621: Redefining name 'conn' from outer scope (li
ne 3) (redefined-outer-name)
supplier_orders.py:22:33: W0613: Unused argument 'remarks' (unused-argument)
supplier_orders.py:26:0: C0116: Missing function or method docstring (missin
g-function-docstring)
supplier_orders.py:26:0: C0103: Function name "notifyWarehouse" doesn't conf
orm to snake_case naming style (invalid-name)
supplier_orders.py:30:0: C0116: Missing function or method docstring (missin
g-function-docstring)
supplier_orders.py:30:12: W0621: Redefining name 'conn' from outer scope (li
ne 3) (redefined-outer-name)
supplier_orders.py:37:0: C0116: Missing function or method docstring (missin
g-function-docstring)
supplier_orders.py:37:0: C0103: Function name "pendingCount" doesn't conform
 to snake_case naming style (invalid-name)
supplier_orders.py:37:17: W0621: Redefining name 'conn' from outer scope (li
ne 3) (redefined-outer-name)
supplier_orders.py:44:0: C0116: Missing function or method docstring (missin
g-function-docstring)

-------------------------------------------------------------------
Your code has been rated at 3.79/10 (previous run: 2.41/10, +1.38)


C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
```

Figure 8: Pylint before these fixes: 3.79/10.

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>pylint supplier_orders.py


--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 9.71/10, +0.29)


C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>flake8 supplier_orders.py


C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>bandit -r supplier_orders
.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-15 13:42:09.764755+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 60
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 9: Final check: Pylint 10.00/10, Flake8 clean, Bandit no issues.

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git add supplier_orders.p
y

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git commit -m "Fix Pylint
 issues: snake_case names, docstrings, remove globals, store remarks"
[main 10b363c] Fix Pylint issues: snake_case names, docstrings, remove globa
ls, store remarks
 1 file changed, 46 insertions(+), 20 deletions(-)

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>mkdir reports\after

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>pylint supplier_orders.py
 > reports\after\pylint_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>bandit -r supplier_orders
.py > reports\after\bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>flake8 supplier_orders.py
 > reports\after\flake8_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 10: Pylint fixes committed and after-reports saved.

6. issues.md and reflection.md

```
# Issues Found and Fixed — supplier_orders.py

**Before:** Pylint 2.41/10, Bandit 3 issues (1 High, 1 Medium, 1 Low), Flake8 4 issues
**After:** Pylint 10.00/10, Bandit 0 issues, Flake8 0 issues

Line numbers refer to the original file (see `reports/before/`).

| Issue | Type | Line(s) | Description | Fix Approach |
|-------|------|---------|-------------|--------------|
| Shell injection (Bandit B605, High) | Security | 21 | `os.system()` passes the supplier name to the operating system shell, so a name like `Acme & del *.*` would run a second, malicious command. | Replaced `os.system("echo ...")` with `print()`, which only displays text, and removed the unused `import os`. |
| SQL injection (Bandit B608, Medium) | Security / Bug | 11 | The INSERT query is built with `%` string formatting, so user text becomes part of the SQL. A supplier like `O'Brien Metals` crashes the query, and crafted input could change it. | Used a parameterised query with `?` placeholders and passed the values as a separate tuple, so SQLite always treats them as data. |
| try/except/pass (Bandit B110, Low) | Error handling | 27-28 | `except Exception: pass` silently hides every error, so a failed cleanup (or a bug) would never be noticed. | Catch only `sqlite3.Error` and print the error message so failures are visible. |
| Global variable order_total (Pylint W0603) | Design | 6, 10, 12 | A global counter is modified inside a function with `global`. It is separate from the database, so it can drift out of sync with the real data and makes functions hard to test. | Removed the global. A new `order_total(conn)` function calculates `SUM(quantity)` directly from the database. |
| Unused argument remarks (Pylint W0613) | Bug | 16 | `markReceived` accepts a `remarks` argument but never uses it, so delivery remarks are silently lost. | Added a `remarks` column to the table and saved the value in the UPDATE query. |
| Redefining conn from outer scope (Pylint W0621) | Design | 4, 9, 16, 24, 31 | A global `conn` is created when the file is imported, and every function parameter named `conn` shadows it, which is confusing. | Moved database creation into `create_store()`, called from `main()`, and added an `if __name__ == "__main__":` guard. |
| camelCase function names (Pylint C0103) | Style | 9, 16, 20, 31 | Names like `placeOrder` break PEP 8, the Python naming convention, which uses snake_case for functions. | Renamed to `place_order`, `mark_received`, `notify_warehouse` and `pending_count`, and updated the calls in `main()`. |
| Missing docstrings (Pylint C0114/C0116) | Documentation | 1, all functions | There is no description of what the module or any function does. | Added a module docstring and a one-line docstring to every function. |
| Lines too long (Flake8 E501) | Style | 5, 11, 32 | Lines of 87-122 characters exceed the 79-character PEP 8 limit and are hard to read. | Split the SQL strings across several lines inside brackets, since Python joins adjacent strings automatically. |
| Missing whitespace around operator (Flake8 E225) | Style | 12 | `order_total+=quantity` has no spaces around `+=`. | Changed to `order_total += quantity` (this line was later removed with the global variable). |
```

Figure 11: issues.md

```
# Reflection – Lab 5: Static Code Analysis

## 1. Which issues were the easiest to fix, and which were the hardest? Why?

The easiest were the Flake8 style issues: the unused `import os`, the missing spaces around
`+=` and the long lines. They were mechanical changes that only affected formatting, so
there was no risk of changing what the program does.

The hardest were the Pylint design issues, especially the global `order_total` variable and
the global `conn`. These could not be fixed by reformatting a line; I had to change how the
program is structured by creating the database inside `create_store()` and calculating the
total from the database with `SUM(quantity)`. I also learned a practical lesson: several of
my edits caused `IndentationError` and `SyntaxError` because pasted lines had the wrong
indentation or were joined onto the previous line. I also saw that when a file has a syntax
error, Bandit skips it and still reports "No issues identified", so I learned to check
"Files skipped (0)" and to always run the program after every change.

## 2. Did the static analysis tools report any false positives? If so, describe one.

I did not find a strict false positive, but one suggestion would have been harmful if I had
followed it blindly. Pylint's C0209 suggested converting the `%`-formatted INSERT query
into an f-string. That would have silenced Pylint while keeping the SQL injection, because
an f-string still pastes user input directly into the SQL. The correct fix was a
parameterised query with `?` placeholders, which satisfied both tools. Bandit's B608 can be
a false positive when no user input reaches the query, but here it was a real bug, since a
supplier named `O'Brien Metals` would crash the original code.

## 3. How would you integrate static analysis tools into your actual software development
workflow?

I would run Flake8 and Pylint inside my editor so problems show up while I type, and add
them to a pre-commit hook so badly formatted code cannot be committed. In a team project, I
would run all three tools automatically on every pull request using a CI pipeline such as
GitHub Actions, and fail the build on any Bandit Medium or High issue, any Flake8 error, or
a Pylint score below about 9.5. I would also keep the tool configuration in the repository
so everyone follows the same rules. Fixing issues one tool at a time with a separate
commit, as in this lab, also made it easy to see and explain each change.

## 4. What tangible improvements did you observe in the code quality, readability, or
potential robustness after applying the fixes?

- **Security:** Both injection risks are gone. Supplier names with quotes or shell
characters are now stored safely as plain data, and no shell command is ever run.
- **Robustness:** The order total is calculated from the database, so it can no longer
drift out of sync with the real data. Cleanup errors are reported instead of hidden, and
```

Figure 12: reflection.md

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>bandit -r supplier_orders
.py > reports\after\bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>flake8 supplier_orders.py
 > reports\after\flake8_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>notepad issues.md

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git add issues.md reports


C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>git commit -m "Add issues
 table and after reports"
[main b5ce5e3] Add issues table and after reports
 4 files changed, 64 insertions(+)
 create mode 100644 issues.md
 create mode 100644 reports/after/bandit_report.txt
 create mode 100644 reports/after/flake8_report.txt
 create mode 100644 reports/after/pylint_report.txt

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 13: issues.md and after-reports committed.

7. Pushing to GitHub

```
C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>   git push -u origin mai
n
Enumerating objects: 26, done.
Counting objects: 100% (26/26), done.
Delta compression using up to 20 threads
Compressing objects: 100% (22/22), done.
Writing objects: 100% (24/24), 6.33 KiB | 809.00 KiB/s, done.
Total 24 (delta 6), reused 0 (delta 0), pack-reused 0 (from 0)
remote: Resolving deltas: 100% (6/6), completed with 1 local object.
To https://github.com/Vocod3r/L5_18_supplier_orders.git
   9b72a43..e7b015b  main -> main
branch 'main' set up to track 'origin/main'.

C:\Users\Vipin\OneDrive\Desktop\SE_Lab\git\Software_engineering_Course_assig
nments\SE_LAB5_PES1UG24AM321\L5_18_supplier_orders>
```

Figure 14: Pushing to the forked repository.

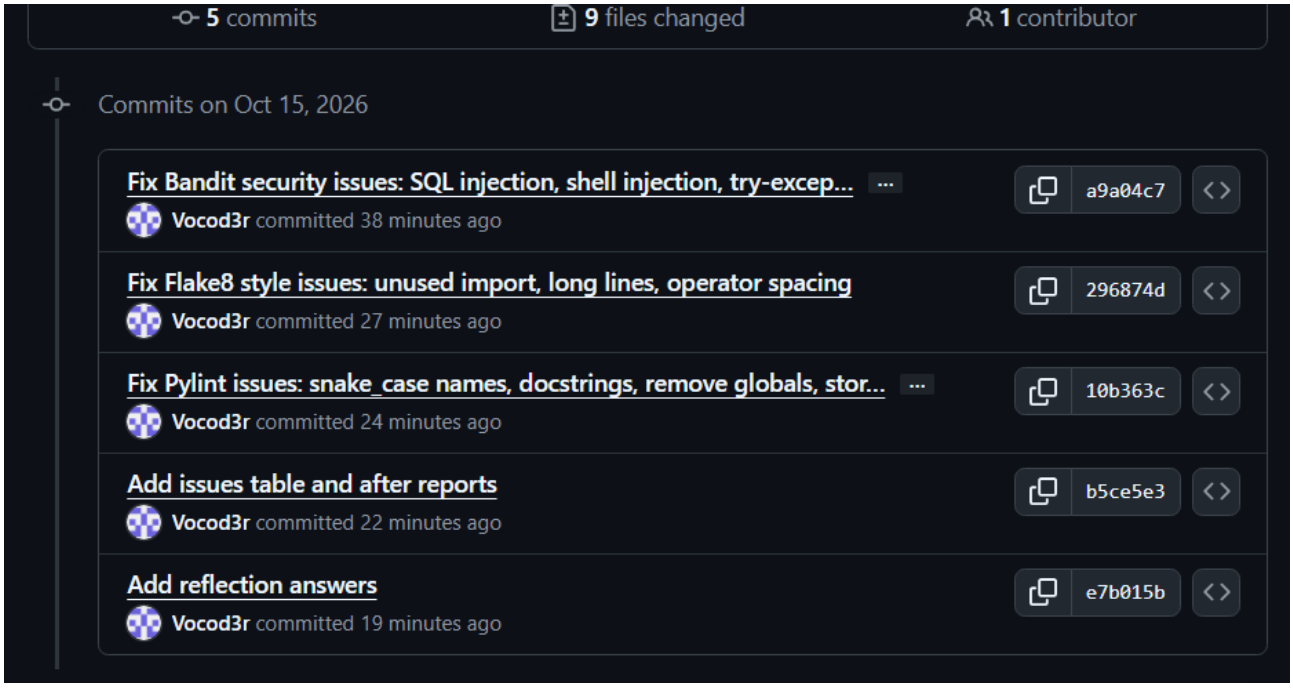


Figure 15: Commit history on GitHub.